

Intercepting Microsoft 365 Copilot traffic: the two real blockers, and what closing each one costs

Written 2026-09-21, as a follow-up to [copilot-desktop-apps-coverage-gap.html](#) 's disambiguation of the word "Copilot." That doc ruled Microsoft 365 Copilot **out of scope permanently** for a simple reason: it's a different company's product, talking to a different backend, with no shared infrastructure to intercept via anything built for GitHub Copilot. This doc investigates that question properly on its own terms: **could a local listener the client is redirected to, relaying to the real backend, work against Microsoft 365 Copilot specifically?**

Short answer: not through any existing lever or capability — but, on working the alternatives through in full, this isn't a dead end the way it first looked. Both reasons below have an identified, buildable path forward, checked against Microsoft's own current admin documentation and real reverse-engineering, not guessed — each at a real, specific cost rather than a structural impossibility. That changes what kind of conclusion this is: not "closed," but "open, at a cost this section spells out, pending a resourcing and risk decision." See **Net assessment** for what that means in practice.

What Microsoft 365 Copilot actually is

Microsoft's own public description: an AI assistant integrated into Word, Excel, PowerPoint, Outlook, Teams, Loop, and Whiteboard. A user's prompt is grounded in their actual organizational data via **Microsoft Graph**, then sent to a large language model on **Azure OpenAI Service**, with the response grounded back into the document/app context. Confirmed distinct from GitHub Copilot on Microsoft's own page: *"a completely separate product from GitHub Copilot."*

Reason 1: there is no redirect lever — the endpoint is fixed, not configurable

Per Microsoft's own admin documentation ([App and network requirements for Microsoft Copilot admins](#)):

- Copilot's enterprise experiences connect to a fixed set of domains: `copilot.cloud.microsoft`, more broadly `*.cloud.microsoft`, and `*.office.com`. These are the same for every tenant — not resolved from any per-tenant or per-device setting.
- Microsoft's explicit guidance to admins is to allow the **entire** `*.cloud.microsoft` domain, stating directly: *"Microsoft doesn't support allowing partial or only selected Microsoft 365*

*application URLs within the *.cloud.microsoft domain.*" That's a statement about network policy, but it doubles as confirmation there's no narrower, single addressable Copilot-specific endpoint an admin (or a config write) could isolate and redirect — the whole wildcard domain is the unit Microsoft expects you to treat atomically.

- No config file, registry key, environment variable, or admin policy surfaced in this documentation that repoints where any of this traffic goes.

Consequence: there's no way to write a single config value and have the client connect somewhere else instead — nothing here determines its own destination from anything write-accessible. This closes the question via the app-config route — but a config key isn't the only way to redirect a connection, so the network-layer alternative below was worked through too, before concluding it doesn't actually get around this either.

A different path to Reason 1: DNS-wildcard redirect + dynamic cert minting

Considered as an alternative once the app-config route above closed: instead of asking the *application* to redirect itself, redirect at the *network* layer, the same way the resident daemon already can for other agents.

A hosts file can't do this — wildcards aren't representable there. `/etc/hosts` (and its Windows equivalent) only matches exact hostnames, one line per FQDN. Since Microsoft explicitly won't publish the real underlying FQDNs behind `*.cloud.microsoft` / `*.office.com` (the same "hyperscale and dynamic" reasoning quoted above), there's no static list to enumerate and redirect. What this actually needs is a **local DNS resolver that performs real wildcard matching** — intercepting any query ending in the relevant suffixes and answering with the listener's own address instead of the real one. Mechanically doable from a privileged daemon; not a new category of capability.

DNS redirection alone produces a connection, not a working one. The client still expects a certificate for whatever real hostname it thinks it dialed. Closing that gap needs the same CA-trust mechanism already used elsewhere in this codebase for other agents: mint a leaf certificate for whatever hostname/SNI the client actually requested, on the fly, signed by a root CA already installed and trusted on the device — the same technique `mitmproxy` / Burp use for arbitrary-host interception, not a fixed pre-issued cert. Reason 2 found no evidence of certificate pinning on this traffic specifically, so this would likely pass ordinary validation — *likely*, not confirmed; pinning wasn't ruled out with certainty either.

The real new cost this introduces: the blast radius is far larger than Copilot.

`*.cloud.microsoft` and `*.office.com` aren't Copilot-specific — SharePoint, OneDrive, Teams, and Outlook itself share them. A wildcard DNS redirect catches all of it. Making this Copilot-only would require the listener to inspect the SNI/Host per connection and decide, live, which hostnames to actually terminate-and-relay versus which to pass through untouched — and Microsoft's own guidance says the opposite of that: "*Microsoft doesn't support allowing partial or*

only selected...URLs within `*.cloud.microsoft` ... allow the entire domain." Selective interception inside that wildcard is close to the exact shape of thing their docs already warn causes the Reason 2 failures — so this path to closing Reason 1 makes Reason 2 *more* likely to bite, not less.

And it only ever closes Reason 1. Landing the connection on the listener doesn't touch the SignalR relay problem underneath it — Design A/B below would still be the only two shapes available for what to actually do with the traffic once it arrives.

Reason 2: the traffic is a persistent SignalR WebSocket, not request/response HTTP — and Microsoft documents interception breaking it

Every interception mechanism this codebase has actually built — including the `forward()` /Optimus tunnel every `BaseUrl` agent uses — is shaped around discrete HTTP request/response pairs: a request comes in, gets relayed or answered, a response goes back. Microsoft 365 Copilot's traffic is not that shape, and this is now confirmed at the protocol level, not just at the network-connectivity level.

Official Microsoft documentation confirms the connectivity requirement. Per the admin doc's **WebSockets (WSS) protocol requirements** section:

Verify that your network supports full WSS connectivity from user devices running Microsoft 365 applications to the following domains: Microsoft Copilot enterprise experiences: `*.office.com`, `*.cloud.microsoft` and `copilot.cloud.microsoft`.

And, listed as a typical cause of "*Copilot application failures*":

Network devices attempting to perform Transport Layer Security (TLS) inspection of connections

Independent reverse-engineering confirms the actual protocol, not just that some WebSocket is involved. A third-party project (`cramt/m365-copilot-proxy`) built a working proxy for the built-in BizChat/Office-web Copilot experience specifically (Word/Excel/etc., not consumer Bing Copilot — the two are architecturally distinct and easy to conflate; an earlier pass of this research briefly did), which required capturing and matching the live wire protocol, not just guessing at it:

- **Transport:** SignalR-over-WebSocket, at `wss://substrate.office.com/m365Copilot/Chathub/{oid}@{tid}` — the auth token rides in the URL query string, not a header.
- **Handshake:** a JSON protocol-negotiation frame (`{"protocol":"json","version":1}`), then typed frames (invocation, stream item, completion, ping, close) separated by `0x1E` record-

separator bytes — genuine, verifiable SignalR wire-protocol detail.

- **Keep-alive:** the client must answer server ping frames or the connection dies — a real, bidirectional, stateful protocol, not a one-way stream.

A related doc on Copilot's newer "Cowork" agentic feature ([Cowork network endpoints](#)) is direct about the failure mode a naive interceptor hits:

SSL/TLS inspection isn't supported and might interrupt long-lived SSE connections, which can result in message delivery failures, retries, or frozen tasks.

What this does and doesn't prove. Microsoft's language describes what happens with *generic corporate TLS-inspecting proxy appliances* — hardware typically tuned for short-lived HTTP request/response, which often mishandle long-lived, stateful connections (aggressive idle timeouts, buffering that breaks keep-alives, no awareness of SignalR's own ping/pong contract). It is not a claim that no relay could ever handle this traffic — a purpose-built proxy that understands the SignalR framing, holds the connection open, and answers pings correctly is a solved class of problem in general (this is how API gateways and service meshes handle WebSocket/SignalR traffic routinely). No evidence of application-level certificate pinning (an absolute technical block, distinct from a reliability complaint) was found in this pass — the language throughout is about connection fragility under naive inspection, not a stated refusal to accept a foreign certificate.

A genuinely open, unresolved wrinkle: SignalR's standard client behavior is to `negotiate` over plain HTTP first, receive a list of transports the server supports, and *fall back* to Server-Sent-Events or long-polling when a WebSocket upgrade fails — this exists specifically for networks that block WS upgrades, which is exactly this scenario. The reverse-engineering above didn't observe or document that fallback in practice, so it's unconfirmed whether Microsoft's Chathub deployment actually honors a downgrade or is configured WebSocket-only. If it does downgrade, the interception question changes shape entirely: forcing the WS upgrade to fail might push the client onto a transport (HTTP long-polling) that existing request/response relay infrastructure already knows how to handle, without needing to build a new SignalR-aware WebSocket relay at all. Unconfirmed either way — a real next step if this is ever revisited, not something to treat as settled.

What remains genuinely unverified: whether this codebase's own relay infrastructure (`forward()` /Optimus, or a hypothetical new listener kind) is shaped to proxy a persistent SignalR WebSocket (or, per the wrinkle above, a forced-fallback long-polling transport) without the failure modes Microsoft describes. Everything built so far is request/response-shaped. Either path would be new, real engineering work, not a reuse of anything that exists today — and it would only be worth attempting after Reason 1 is somehow solved, which it currently isn't.

Considered: bridge WSS↔HTTP around Optimus's HTTP-only relay

A natural next idea, raised and worked through in this investigation: since Optimus's `forward()` only ever speaks HTTP, could our own listener terminate the client's WebSocket, translate each frame into something Optimus *can* relay, and translate the response back into WS frames on the way out? Worked through fully, this splits into two concrete designs, and both run into a real, structural problem rather than a shallow one.

Design A — bridge to a *different*, genuinely HTTP-shaped backend. Microsoft does expose an official HTTP/SSE surface for Copilot chat: the Graph `chatOverStream` API, a developer-facing REST endpoint that returns a plain `text/event-stream` response. In principle, the listener could translate each client "send message" frame into a POST against that endpoint, relay it through Optimus unchanged, and translate the SSE response back into WS frames.

The problem: **that endpoint is a different product surface**, built for third-party developers writing their own bots against Copilot — not the backend the built-in Word/Excel UI actually talks to. It almost certainly lacks the same document-grounding, citations, and session context the native experience depends on. This wouldn't be *intercepting* the real exchange; it would be silently substituting a different, likely-degraded conversation for it. That defeats the actual point of wanting this visibility in the first place — governing what really happened, not a lookalike generated on the side.

Design B — a true transport bridge that preserves the real exchange. Encode the actual SignalR frames as opaque bytes in an HTTP body, relay that blob through Optimus untouched (Optimus doesn't need to understand SignalR at all here, just move bytes — within what `forward()` already does), and translate back on the way out.

The problem, as first stated: **something on the far end still has to open a real WebSocket to `substrate.office.com`**. Optimus's `forward()` speaks HTTP to the upstream; it has no "open a WebSocket to the real backend and tunnel these bytes through it" capability today. This design doesn't eliminate the WebSocket-handling problem — it relocates *who* has to solve it, from this codebase's listener to Optimus itself.

That relocation is a real cost, not a dead end. Optimus isn't code in this repo, but it isn't a true third-party black box either — it's Zscaler's own cloud policy gateway. "Optimus needs to learn to carry a SignalR session" is a legitimate cross-team engineering proposal, not something to write off as out of reach. What it actually requires: Optimus would need to do for a live, stateful WebSocket what `forward()` does today for a single HTTP request/response — hold the connection open for its full duration, preserve (or at least not corrupt) the SignalR frame boundaries, answer keep-alive pings on whichever leg needs them, and still apply policy to the content flowing through it rather than just moving bytes blindly. That's a materially different capability than tunneling one-shot request/response pairs — bigger and longer-lived than anything else in this investigation — but it's an engineering investment to scope and propose, not a structural impossibility.

The sharper, cheaper alternative, and why it's a tradeoff rather than a free win. If instead the listener itself opened the real WebSocket to Microsoft directly — bypassing Optimus entirely — that's mechanically buildable today, with no new dependency on Optimus at all. But that only works safely for traffic that's low-stakes and not worth policy-inspecting. M365 Copilot's chat content is the opposite: it's exactly the traffic worth inspecting — the actual prompts and completions, the real DLP-relevant material. Bypassing Optimus gets the mechanism working fastest, at the cost of discarding the one property that made building it worthwhile in the first place. It's the fallback if the Optimus investment isn't prioritized, not a substitute for it.

Net: Design A trades away fidelity (a different, likely-degraded backend). Design B, done properly, trades away nothing — but costs real, cross-team engineering time in a system outside this repo. Design B's bypass variant is available now, cheaply, at the cost of the policy enforcement this was supposed to provide. None of the three is blocked by anything Microsoft controls — the constraint is entirely about what this org is willing to invest, and where. All three still sit behind Reason 1, which nothing in this section touches — this section answers "if we already had the traffic, could we route it through Optimus," not "how do we get the traffic."

Net assessment

Blocker	Status	Path forward, and its cost
Reason 1 — no redirect lever	No app-level config lever exists; the endpoint is a fixed, wildcarded, tenant-wide domain	DNS-wildcard redirect + dynamic cert minting — mechanically doable, at the cost of terminating TLS on <i>all</i> M365 traffic sharing the wildcard (SharePoint, OneDrive, Teams, Outlook), not just Copilot
Reason 2 — persistent SignalR WebSocket	Confirmed protocol-level mismatch with this codebase's HTTP-only relay infrastructure; Microsoft documents naive TLS inspection breaking this traffic	Optimus gaining SignalR-tunnel capability — a real, cross-team engineering investment in a system outside this repo; or bypass Optimus entirely, cheaply, at the cost of losing policy enforcement on exactly the traffic that matters

Recommendation: treat this as a resourcing and prioritization decision, not a closed door. Pursuing it means deliberately accepting the Reason 1 blast-radius increase (decrypting and re-terminating TLS for all of SharePoint/OneDrive/Teams/Outlook sharing the wildcard, not just Copilot) and either committing real cross-team engineering time to add SignalR-tunnel capability to Optimus, or accepting the cheaper bypass variant's loss of policy enforcement on the traffic that's the whole point. Worth scoping as an actual proposal to whoever owns Optimus if there's product appetite for it — not something to build unilaterally inside `ai-protect` / `ai-gateway` alone, and not something to write off as impossible.

Sources

- [App and network requirements for Microsoft Copilot admins](#) — Microsoft Learn, updated 2026-09-08 (official)
- [Microsoft Copilot Cowork network endpoints \(Preview\)](#) — Microsoft Support (official)
- [Microsoft 365 URLs and IP address ranges](#) — Microsoft Learn (official)
- [cramt/m365-copilot-proxy](#) — [M365 Copilot API docs](#) — third-party, reverse-engineered against a real working proxy (not Microsoft-published; cited for the specific SignalR/WebSocket protocol detail Microsoft's own docs don't spell out)